

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-07-01T06:59:11Z · Source: `pom.xml` @ `61ed8c3` · Health Score: **0 / 100** Grade D — high risk (main, unmerged)

Executive summary

- **24** dependency coordinates scanned · **75** CVE findings — **16 CRITICAL / 46 HIGH / 12 MEDIUM / 1 LOW** — all still present on `main` pending merge.
- **Remediation PR open:** [#56](#) (`fix/depSCAN-20260701-062524` → `main`) bumps `log4j-core/api`, `jackson-databind`, `guava`, `mysql-connector-java`, and pins `protobuf-java`, clearing **Log4Shell (CVE-2021-44228)** and 60+ other CVEs; also removes the typosquatted `com.fastxml.jackson.core:jackson-databind` entry. `mvn test` package — **PASS**.
- **Latest gate outcome:** BLOCK — posted as a [PR review](#) on #56. Tracking issue: [#57](#).
- **Supply-chain:** BLOCK even after this PR — `commons-io:2.4` (CVE-2024-47554, HIGH) is untouched by the PR, the GPL-2.0 license violation on `mysql-connector-java` persists (a version bump doesn't change the license), and the untrusted plain-HTTP repository mirror in `pom.xml` was not removed by this round.
- **OWASP Dependency-Check (Stage 4 re-scan):** inconclusive this run — no `NVD_API_KEY` configured and the local warm-cache DB (schema 11.0) is incompatible with the resolved `dependency-check-maven:12.2.2` plugin; flagged as a required environment fix in issue #57, not fabricated as a pass.

Human action required. Nothing merges automatically. A reviewer must (1) merge PR #56 to actually clear the 16 CRITICAL / most HIGH CVEs on `main`, then (2) close out issue #57 — bump `commons-io` to 2.14.0+, resolve the `mysql-connector-java` GPL-2.0 license (accept exception or replace with `com.mysql:mysql-connector-j`), remove the untrusted HTTP mirror, and configure `NVD_API_KEY` so future CVE re-scans complete.

Health score breakdown (current — `main`, PR #56 not yet merged)

Factor	Deduction
Unresolved CRITICAL CVEs (16 × -15)	-240
Unresolved HIGH CVEs (46 × -8)	-368
Unresolved MEDIUM CVEs (12 × -2)	-24
Supply-chain BLOCK findings — typosquat, untrusted repo, GPL license (3 × -10)	-30
Score (floored at 0)	0 / 100

Projected after PR #56 merges (before issue #57 is resolved): removing the typosquat and bumping `log4j/jackson/guava/mysql/protobuf` clears 16 CRITICAL and 45 of 46 HIGH CVEs. Remaining deductions: ~~`commons-io` CVE-2024-47554 HIGH (-8), 2 C-type MEDIUM findings (-4), GPL-2.0 license violation (-10), untrusted HTTP repo mirror (-10)~~ → projected ****68 / 100 (Grade C)****. Reaching Grade A requires clearing all three items tracked in issue #57.

Top Risks (ranked, per Stage 2 risk report)

Coordinate	Risk	Band	Top CVE	Status
------------	------	------	---------	--------

<code>com.fastxml.jackson.core:jackson-databind:2.9.8</code> (typosquat)	n/a	CRITICAL (flagged)	supply-chain	Fixed in PR #56 — removed
<code>org.apache.logging.log4j:log4j-core:2.14.1</code>	7.8	HIGH	CVE-2021-44228 (10.0)	Fixed in PR #56 — → 2.26.0
<code>com.fasterxml.jackson.core:jackson-databind:2.9.8</code>	7.8	HIGH	CVE-2019-14379 (+53 more)	Fixed in PR #56 — → 2.22.0
<code>org.apache.logging.log4j:log4j-api:2.14.1</code>	6.8	HIGH	CVE-2026-34479	Fixed in PR #56 — → 2.26.0
<code>mysql:mysql-connector-java:8.0.30</code>	6.7	HIGH	CVE-2023-22102 + GPL license	Partially fixed — CVE cleared (→ 8.0.33), license violation remains
<code>com.google.protobuf:protobuf-java:3.19.4</code>	6.7	HIGH	CVE-2024-7254	Fixed in PR #56 — pinned 3.21.7
<code>com.google.guava:guava:24.1.1-jre</code>	6.6	HIGH	CVE-2023-2976	Fixed in PR #56 — → 32.0.1-jre
<code>commons-io:commons-io:2.4</code>	—	HIGH (Grype)	CVE-2024-47554	Not in this PR — open in issue #57

Remediation Activity

Dependency	old → new	CVEs cleared	PR	Merged?
<code>org.apache.logging.log4j:log4j-core</code> / <code>log4j-api</code>	2.14.1 → 2.26.0	CVE-2021-44228 (Log4Shell), CVE-2021-45046	#56	No — BLOCKed
<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8 → 2.22.0	CVE-2019-14379 + 53 more	#56	No
<code>com.google.guava:guava</code>	24.1.1-jre → 32.0.1-jre	CVE-2023-2976, CVE-2020-8908, CVE-2018-10237	#56	No
<code>mysql:mysql-connector-java</code>	8.0.30 → 8.0.33	CVE-2023-22102	#56	No
<code>com.google.protobuf:protobuf-java</code>	3.19.4 → 3.21.7 (pinned)	CVE-2024-7254	#56	No
<code>com.fastxml.jackson.core:jackson-databind</code> (typosquat)	removed	supply-chain (impersonation)	#56	No

Supply-Chain Findings

Type	Coordinate	Detail	Action
Typosquat	<code>com.fastxml.jackson.core:jackson-databind:2.9.8</code>	Missing "er" in groupId, impersonates <code>fasterxml</code> , fails Central resolution	Removed in PR #56
Untrusted repository	<code>internal-untrusted-mirror</code> (<code>http://insecure-mirror.example.net/maven2</code>)	Plain-HTTP, non-Central repository declared in <code>pom.xml</code>	Open — tracked in issue #57
License violation	<code>mysql:mysql-connector-java:8.0.33</code>	GPL-2.0-with-classpath-exception in a permissive-only project	Open — tracked in issue #57 (human license decision needed)
Known-vulnerable	<code>commons-io:commons-io:2.4</code>	CVE-2024-47554 (GHSA-78wr-2p64-hpwj), HIGH, fix 2.14.0 available	Open — tracked in issue #57

Tests

- `mvn test package` on PR #56: **2/2 tests passed**, build packaged successfully.

Gate (Stage 4) — current verdict: **BLOCK**

Check	Result
Unit tests	PASS
OWASP CVE (0 unresolved CRITICAL/HIGH)	INCONCLUSIVE (NVD access unavailable this run — see issue #57)
Supply-chain audit	FAIL (BLOCK — commons-io CVE, GPL license, untrusted repo)

Trend vs. Previous Run

- Health score: **0** → **0** (Δ 0) — `main` itself is unchanged; the fix lives on an unmerged PR (#56), same pattern as the prior daily runs (`fix/depSCAN-20260611-*` ... `fix/depSCAN-20260630-*`), none of which merged into `main` .
- CVEs addressed by an open PR this cycle: **≈61** of 75 (16 CRITICAL Log4Shell-family + jackson-databind's 54-CVE chain + guava/mysql/protobuf singles); **14** remain open regardless of merge (commons-io HIGH/MEDIUM family + the license and untrusted-repo findings).
- Process observation for stakeholders:** the pipeline has now produced 20+ consecutive daily remediation PRs (2026-06-11 through 2026-07-01) with zero merges recorded on `main` . The scan/score/fix/gate automation is working end-to-end; the bottleneck is the human merge step. Recommend routing PR #56 (and the #57 follow-ups) to an owner for review this week.

Appendix — Full Findings

- Raw scan: `depSCAN-report.json` (source_sha `61ed8c3140d76e3a19a88954e834d39c9f7635fb`)
- Ranked risk backlog: `depSCAN-risk-report.json`
- Supply-chain audit + SBOM: `depSCAN-supplychain-audit.json` , `target/sbom.cdx.json`
- Per-stage reports: `depSCAN-reports/CVE-Report.md` , `depSCAN-reports/Risk-Scoring-Report.md` , `depSCAN-reports/Remediation-Report.md`

Machine-readable sources: `depSCAN-report.json` , `depSCAN-risk-report.json` , `depSCAN-supplychain-audit.json` .
Generated by the Dependency & Supply-Chain Plugin — Stage 5 (Audit Trail).